

The Anatomy of a Quiet Intrusion

A forensic clinic on hunting a valid-account attacker — built on the Northpeak Descent hunt.

AUTHOR

Aboubacar Sakho

DISCIPLINE

Threat Hunting

STACK

Sentinel • MDE •
KQL

USE

Teaching •
Reference

Why this clinic exists

Most intrusions that matter don't look like intrusions. There is no exploit, no malware detonation, no red banner. There is an administrator, doing administrator things, at a slightly wrong time from a slightly wrong place. This clinic teaches you to see that — using a real hunt, Northpeak Descent, where a threat actor held the front door open for hours and nothing tripped.

It is organised the way an investigation actually unfolds: the story first, then the questions the story forces you to ask, then the procedure that answers them, then the thinking that separates a hunter from a log-reader, and finally the telemetry and patterns you must be able to recognise on sight. Read it once end to end; keep the last two sections as a bench reference.

What happened at Northpeak

On the evening of 16 June 2026, the Northpeak Logistics estate — two Windows machines and a Linux host — lit up with hundreds of failed logons. To a tier-1 eye it reads as a brute-force break-in against the Linux box. It is not. The failures are an internet SSH sprayer hammering a common target, and they never succeed. While that noise plays, a second, silent thing happens: a legitimate administrator account signs in cleanly over Remote Desktop from an external address and begins to work.

The operator takes a foothold on the workstation, then the server, both by simply logging in. They move to the Linux host to build a toolkit — checking what they can escalate with, testing whether the Windows boxes are reachable using nothing but a shell built-in, and installing a lateral-movement tool. They pivot back into Windows from inside the network, confirm their own privileges, and plant a hidden startup task disguised as a company sync utility. That task beacons out to three look-alike domains — but the network sensor only ever records one of them. Finally, they export the customer database from the server and upload it over the same channel. Then they are gone, having disabled nothing and dropped almost nothing.

THE ONE SENTENCE TO REMEMBER

The loud event was the decoy; the quiet event was the intrusion. A hunter's first job is to refuse the story the volume is telling.

What threat hunting actually is

Alerting is reactive: a rule fires, an analyst responds. Hunting is **proactive and hypothesis-driven** — you assume a capable adversary is already inside and has evaded your rules, and you go looking for their traces on purpose. The Northpeak case is the perfect argument for it: *not a single control fired*, because the attacker did nothing a control was written to catch. If you wait for alerts here, you never learn the customer database left the building.

ALERTING ASKS

"Did a known-bad thing happen?"

Answered by signatures and rules. Blind to novel or legitimate-looking activity.

HUNTING ASKS

"If a skilled actor were here, what would I see — and can I prove they are or aren't?"

Answered by hypotheses tested against raw telemetry.

The hunt loop

Every hunt cycles through four moves, and Northpeak is a clean example of each:

1. **Hypothesise.** "A valid account was abused for interactive access." Driven by the brief's hint that the real entry authenticated clean.
 2. **Gather & scope.** Pull the six MDE tables, scoped to the three hosts, across the intrusion window.
 3. **Test & pivot.** Separate success from failure, external from internal, human from machine — then pivot on the identity and address that thread the case.
 4. **Conclude & hand off.** Build the chain, produce IOCs and ATT&CK mapping, and — crucially — state what the *absence* of evidence proves.
-

What had to be investigated

A good brief hands you the shape of your ignorance. Northpeak's open questions were the spine of the whole hunt — each is a hypothesis waiting to be proven or killed:

UNKNOWN	WHY IT'S HARD	HOW IT WAS RESOLVED
Which foothold came first?	The data's shape screams Linux-first (the brute force)	Single timeline of <i>successful</i> logons → Windows first by 90 min
How was each host reached?	Multiple sources, real and decoy	Correlate inbound 3389 + logon type + source IP per host
The internal pivot path & method	Internal RDP blends with admin traffic	Follow the anomalous internal source (10.2.0.30) into both boxes
How persistence was configured	Named to look legitimate	Registry Run-key write by PowerShell, hidden window
The full C2 infrastructure	Network sees only part of it	Cross-source: recover hidden domains from process/file consoles
What data left, and from where	Exfil looks like a normal web request	Stage-then-upload pair on srv01, session-correlated

The general method, and this hunt's version of it

Hunts and incident investigations share a backbone. Two frameworks are worth internalising, and then the concrete steps this hunt used.

Frameworks worth carrying

- **PICERL (SANS IR).** Preparation → Identification → Containment → Eradication → Recovery → Lessons learned. A hunt lives mostly in *Identification*, feeding the rest.
- **The Pyramid of Pain.** Hashes and IPs are cheap for an adversary to change; tools, and especially TTPs, are expensive. Northpeak's most durable findings are TTPs — valid-account abuse, LOTL, disguised persistence — not the IPs.

This hunt, step by step

1. **Scope every query.** `where DeviceName has_any (...)` on a shared workspace, always. Unscoped results are another estate's data and will fabricate a false story.
 2. **Kill the noise.** Filter to `ActionType = "LogonSuccess"` from external addresses. The 200-line brute force collapses to zero relevant rows.
 3. **Build one timeline.** Put Windows and Linux successful logons on the same axis, sorted by true event time. Let timestamps — not intuition — order the footholds.
 4. **Pivot on identity + source.** One account (sancadmin) and one address (148.64.103.173) recur; wherever a new internal source appears (10.2.0.30), follow it.
 5. **Separate human from machine.** Use process lineage and remote-session fields to isolate hands-on-keyboard work from automation (see §6).
 6. **Cross the consoles.** When the network table goes quiet where you expect a beacon, jump to process and file telemetry — the launch trace survives even when the connection wasn't logged.
 7. **Reason from absence.** No Defender tamper events, nothing dropped on disk beyond a script. That silence is the finding: they didn't need to evade because they looked authorised.
 8. **Assemble & hand off.** Chain the phases, extract IOCs, map ATT&CK, write recommendations.
-

Mental models that break the case

Tools find rows; models find intrusions. These six habits of thought are what actually solved Northpeak — and they transfer to any hunt.

1 • Signal versus noise

Volume is not importance. A loud, failing brute force is often a curtain. Ask of any noisy event: *did it succeed, and does it connect to anything else?* If not, characterise it, label it decoy, and set it aside — deliberately, in writing, so you don't relitigate it.

2 • Prove the order, don't assume it

Causation lives in sequence. The plausible narrative (Linux → Windows) was false; only a merged, time-true timeline revealed Windows-first. Never let the *shape* of the data — which events are loudest or most numerous — stand in for the *order* of events.

3 • Absence as evidence

The hardest findings are things that didn't happen. Expected-but-missing telemetry is data: a quiet network table next to a busy process table means a stealthier method, not "nothing occurred." No tamper events means evasion-by-legitimacy, not "they forgot to evade."

4 • Identity is the thread

In a valid-account intrusion, the account *is* the malware. Pivot relentlessly on the identity and its source address; the anomaly is not what the account does but *where and when* it does it.

5 • Human versus machine

Modern estates are mostly automation talking to itself. Learn your baseline so hands-on-keyboard work stands out — a typo (`sudo -1` before `sudo -l`), an interactive shell parent, a leaked client hostname. The mistake is often the tell.

6 • One console is never the whole truth

Each telemetry source has blind spots. A C2 call with a short timeout may never complete a logged network connection, yet the command that launched it is fully recorded process-side. Triangulate across consoles before you conclude a thing didn't happen.

What every hunter must recognise

This is the bench reference. Know these tables and fields cold; the entire Northpeak reconstruction is built from them.

The six MDE tables

TABLE	ANSWERS	NORTHPEAK USE
DeviceLogonEvents	Who authenticated, how, from where	Foothold, pivot, session correlation
DeviceProcessEvents	What ran, its command line and ancestry	sudo, whoami, beacons, exfil, human/machine split
DeviceNetworkEvents	Outbound/inbound connections	Inbound RDP, the one visible C2 domain
DeviceFileEvents	File create/modify/rename	Tool install, script drop, staged CSV, PSScriptPolicyTest traces
DeviceRegistryEvents	Registry writes	The NorthpeakSyncTray Run key
DeviceEvents	Misc security-relevant events	Supporting context / tamper-event absence

THE TRAP THAT RUINS TIMELINES • TIMESTAMP VS TIMEGENERATED

On Linux (and cross-platform) MDE, `TimeGenerated` is *ingestion* time and can scramble your order; `Timestamp` is true *event* time. Sort and correlate on `Timestamp`. Getting this wrong silently reorders your intrusion and can flip which foothold came "first."

Logon types you must read instantly

TYPE	NAME	MEANS	HUNT SIGNAL
2	Interactive	Local console logon	Physical / VM console
3	Network	SMB, auth to a service	Brute-force noise; pre-auth to RDP
10	RemoteInteractive	RDP session	Hands-on-keyboard remote access
7	Unlock	Session unlocked	Operator returning to a live session
4 / 5	Batch / Service	Scheduled task / service	Usually automation baseline

The fields that catch a careless operator

- `InitiatingProcessRemoteSessionDeviceName` / `...RemoteSessionIP` — the client's own hostname and LAN address, leaked into every remote action. At Northpeak this exposed LORANSE / 192.168.69.75 and became a one-field operator filter.
- `IsInitiatingProcessRemoteSession` — true means the action rode a remote session; a clean human/machine discriminator.
- `InitiatingProcessParentFileName` — ancestry. Human PowerShell traces to `explorer.exe` (an interactive desktop); automation traces to `services.exe` / `svchost.exe` / `gc_worker.exe` under SYSTEM.
- `LogonId` — ties a process back to a specific session; the key to answering "which session did the exfil run in?"
- `IsLocalAdmin` / token groups — confirms privilege of the authenticating account.

Signatures to know on sight

BRUTE-FORCE DECOY

Many `LogonFailed` (type 3) from one external IP, junk usernames, tight window, *zero successes*. Loud, harmless, and often cover for something quiet.

VALID-ACCOUNT ABUSE

A clean `LogonSuccess` from an unusual external IP at an unusual hour, immediately followed by `RemoteInteractive`. No failures precede it.

LIVING OFF THE LAND

Recon and movement via built-ins — `whoami`, `sudo -l`, `/dev/tcp`, native PowerShell. No malware to signature.

DISGUISED PERSISTENCE

A Run-key or scheduled task with a legitimate-sounding name, launching hidden PowerShell with `-WindowStyle Hidden -ExecutionPolicy Bypass`.

ENCODED-COMMAND CHATTER

Constant base64 PowerShell under SYSTEM from `gc_worker.exe` is *normal* Azure compliance polling. Discriminate by lineage + identity + decoded payload.

AUTOMATED BEACONING

Fixed-interval outbound HTTPS to a look-alike domain. Regular spacing = scripted/scheduled callback, not a human.

STAGE-THEN-EXFIL

An archive/CSV created in a temp path, then a web upload seconds later with the data named in the URL query string.

CONSOLE BLIND SPOT

A beacon absent from the network table but present as a process command line + `__PSScriptPolicyTest` file artifact. Cross-source or miss it.

The analyst's checklist

Pin this above the keyboard. It is the Northpeak method, generalised.

1. Scope to your assets before reading a single row.
2. Separate success from failure; work only what succeeded.
3. Separate external from internal; separate human from machine.
4. Build one timeline on true event time (`Timestamp`), not ingestion time.
5. Prove the order; never let volume or plausibility set the sequence.
6. Pivot on identity and source address, not on individual events.
7. When a console goes quiet where you expect noise, cross to another.
8. Write down what's absent and what it proves.
9. Label decoys explicitly so you don't chase them twice.
10. Finish with a chain, IOCs, ATT&CK, and a plain-language judgement.

THE LESSON OF NORTHPEAK

The strongest adversaries won't break your controls — they'll make sure your controls have no reason to look. Hunt the legitimate-looking, reason from the silence, and never trust the loudest thing in the room to be the important one.